

Information Security Management System (ISMS) Policy

Policy ID: ISMS-001

Version: 2.1

Effective Date: January 15, 2025

Next Review Date: January 15, 2026

Owner: Chief Information Security Officer (CISO)

1. Purpose

The purpose of this policy is to establish and maintain an Information Security Management System (ISMS) that protects the confidentiality, integrity, and availability of the organization's information assets. This policy provides a framework for managing information security risks.

2. Scope

This policy applies to all employees, contractors, consultants, temporary staff, and third-party vendors who access or manage organizational information systems and data. It covers all information assets owned or processed by the organization.

3. Policy Statements

1. The organization shall implement appropriate technical and administrative controls to protect information assets.
2. Senior management shall demonstrate visible commitment to information security.
3. All personnel shall receive appropriate security awareness training annually.
4. Access to information and systems shall be granted on a need-to-know and least privilege basis.
5. Information security incidents shall be reported immediately through the established incident management process.

4. Roles and Responsibilities

- **Chief Information Security Officer (CISO):** Overall accountability for the ISMS.
- **Department Heads:** Ensure compliance within their departments.
- **Employees:** Comply with all security policies and report incidents.
- **IT Department:** Implement and maintain technical security controls.

5. Compliance and Enforcement

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment. All exceptions must be approved in writing by the CISO.

6. Policy Review

This policy shall be reviewed annually or when significant changes occur in the business or threat landscape.

Approved by:

Chief Executive Officer

Date: January 10, 2025